

CYBERSECURITY GOVERNANCE DOCUMENT

WHITE PLAINS HOSPITAL

Cybersecurity Risk Register

Governance, Risk & Compliance Program

DOCUMENT INFORMATION

Prepared By:	Nadhir Choudhury — GRC Analyst
Organization:	White Plains Hospital — White Plains, New York
Department:	Information Security / GRC
Document Title:	Cybersecurity Risk Register
Version:	1.0
Date:	April 2026
Classification:	CONFIDENTIAL — Internal Use Only
Review Cycle:	Quarterly
Framework Alignment:	NIST Cybersecurity Framework (CSF) HIPAA Security Rule
Next Review Date:	July 2026

ABOUT THIS DOCUMENT

This Cybersecurity Risk Register was developed as part of the White Plains Hospital Information Security GRC Program. It identifies, assesses, and documents cybersecurity risks across the organization's people, technology, processes, and third-party vendors. All risks are scored using a likelihood and impact methodology and aligned to the NIST Cybersecurity Framework (CSF) five core functions and HIPAA Security Rule requirements.

SCOPE

In Scope:	All hospital departments, clinical systems, administrative systems, medical devices connected to the network, and third-party vendors with access to patient data or hospital systems.
Framework:	NIST Cybersecurity Framework (CSF) — Identify, Protect, Detect, Respond, Recover
Regulation:	HIPAA Security Rule — Administrative, Physical, and Technical Safeguards
Risk Method:	Qualitative — Likelihood (1–5) × Impact (1–5) = Risk Score (1–25)

DISCLAIMER

This document was created for educational and portfolio demonstration purposes only. All risk scenarios, data, and findings are fictional and based on a simulated healthcare environment. This document does not represent actual security posture of White Plains Hospital and should not be used in any real production environment.

RISK ASSESSMENT OVERVIEW

TOTAL RISKS IDENTIFIED	CRITICAL	HIGH	MEDIUM	LOW
15	1	6	8	0

RISK DISTRIBUTION BY CATEGORY

Risk Category	Risk Count	Avg Score	Highest Score	Risk Level
Access Control	2	14	16	HIGH
Access Management	1	12	12	HIGH
Business Continuity	1	10	10	MEDIUM
Compliance / Training	1	9	9	MEDIUM
Cybersecurity	1	20	20	CRITICAL
Data Protection	1	8	8	MEDIUM
HIPAA Compliance	1	9	9	MEDIUM
Incident Response	1	10	10	MEDIUM
Insider Threat	1	16	16	HIGH
Malware / Ransomware	1	15	15	HIGH
Medical Device Security	1	12	12	HIGH
Physical Security	1	8	8	MEDIUM
Vendor Risk	1	6	6	MEDIUM
Vendor Risk / HIPAA	1	10	10	MEDIUM

TOP PRIORITY RISKS — IMMEDIATE ACTION REQUIRED

Risk ID	Description	Score	Treatment Action Required
WPH-R01	Staff fall for phishing email giving attacker unauthorized access to Epic EHR system	20	IT Security Manager
WPH-R02	Employee shares login credentials with colleague, enabling unauthorized patient record access	16	Privacy Officer
WPH-R04	Hospital employee accesses patient records without clinical justification — insider threat	16	Privacy Officer
WPH-R03	Ransomware attack encrypts all hospital systems causing complete clinical operations shutdown	15	IT Manager
WPH-R05	Unpatched vulnerability in medical device connected to hospital network exploited by attacker	12	IT Manager / Biomedical Engineering

KEY RECOMMENDATIONS TO EXECUTIVE LEADERSHIP

1	IMMEDIATE — 30 Days	Implement mandatory phishing simulation training and deploy MFA on all Epic EHR accounts. Conduct emergency vendor contract audit to identify all missing BAAs.
2	SHORT TERM — 60 Days	Establish formal incident response plan with defined roles. Conduct user access review to deactivate all former employee accounts. Enforce password complexity on all systems.
3	MEDIUM TERM — 90 Days	Implement offsite cloud backup with tested recovery procedures. Complete HIPAA audit log review process. Achieve 100% staff completion of HIPAA security awareness training.
4	ONGOING — Quarterly	Maintain and update this risk register. Conduct quarterly risk reviews with department heads. Monitor vendor compliance and renew BAAs annually.

WHITE PLAINS HOSPITAL | CYBERSECURITY RISK REGISTER | Version 1.0 | April 2026

Likelihood × Impact = Risk Score Scale: 1 (Very Low) to 5 (Very High)															
CRITICAL (Score 20-25)		HIGH (Score 12-19)		MEDIUM (Score 6-11)		LOW (Score 1-5)									
Risk ID	Risk Description	Risk Category	Affected Area	Likelihood (1-5)	Impact (1-5)	Risk Score	Risk Level	NIST CSF Function	Current Controls in Place	Treatment Strategy	Risk Owner	Target Date	Status	Residual Likelihood	Residual Impact
WPH-R01	Staff fall for phishing email giving attacker unauthorized access to Epic EHR system	Cybersecurity	All Departments / EHR	4	5	20	CRITICAL	Protect / Detect	Basic email spam filter in place. Annual HIPAA training mentions phishing briefly.	REDUCE — Implement mandatory phishing simulation training quarterly. Deploy advanced email filtering. Enable MFA on all EHR accounts.	IT Security Manager	June 2026	Open — In Progress	2	4
WPH-R02	Employee shares login credentials with colleague, enabling unauthorized patient record access	Access Control	Clinical Staff / EHR	4	4	16	HIGH	Protect	Password policy exists but is not technically enforced. No monitoring of shared logins.	REDUCE — Enforce unique credentials technically. Implement MFA. Add access monitoring and quarterly user access reviews.	Privacy Officer	May 2026	Open — High Priority	2	3
WPH-R03	Ransomware attack encrypts all hospital systems causing complete clinical operations shutdown	Malware / Ransomware	Entire Hospital	3	5	15	HIGH	Protect / Detect / Recover	Basic antivirus on workstations. No tested backup and recovery plan. No network segmentation.	REDUCE + TRANSFER — Implement network segmentation. Deploy EDR solution. Establish and test offsite backups. Purchase cyber insurance.	IT Manager	July 2026	Open — Critical	2	3
WPH-R04	Hospital employee accesses patient records without clinical justification — insider threat	Insider Threat	EHR / Patient Data	4	4	16	HIGH	Detect / Protect	EHR has audit log capability but logs are not reviewed regularly. No formal access review process.	REDUCE — Implement monthly audit log reviews. Conduct quarterly user access reviews. Establish formal process for investigating access anomalies.	Privacy Officer	June 2026	Open — In Progress	2	3
WPH-R05	Unpatched vulnerability in medical device connected to hospital network exploited by attacker	Medical Device Security	Clinical Equipment / Network	3	4	12	HIGH	Identify / Protect	No formal medical device inventory. Patching is done ad hoc with no defined schedule.	REDUCE — Create complete medical device inventory. Establish monthly patching schedule. Implement network segmentation to isolate device traffic.	IT Manager / Biomedical Engineering	August 2026	Open	2	3
WPH-R06	Third-party billing vendor stores patient PHI without a signed Business Associate Agreement	Vendor Risk	Billing / Patient Data	2	5	10	MEDIUM	Identify / Protect	Vendor contracts exist but have not been reviewed for BAA compliance. No vendor risk program in place.	REDUCE — Conduct immediate vendor contract audit. Obtain signed BAAs from all vendors handling PHI. Establish formal vendor risk program.	GRC Analyst / Legal	May 2026	Open — Urgent	1	4
WPH-R07	Primary server room flood or fire destroys patient data with no tested offsite backup available	Business Continuity	Server Room / All Data	2	5	10	MEDIUM	Recover	Single on-premises server. No tested offsite or cloud backup. No disaster recovery plan documented.	REDUCE — Implement automated daily cloud backup. Document and test disaster recovery procedures quarterly. Define RTO and RPO targets.	IT Manager	July 2026	Open	1	3
WPH-R08	Former employee account remains active after termination, enabling unauthorized system access	Access Control	All Systems	3	4	12	HIGH	Protect	No formal offboarding procedure that includes IT account deactivation. HR and IT processes are not integrated.	REDUCE — Create formal IT offboarding checklist tied to HR termination process. Conduct monthly audit of active accounts against current employee list.	HR Manager / IT Manager	May 2026	Open — High Priority	1	3
WPH-R09	Patient health information transmitted between departments without encryption	Data Protection	Clinical Communications	2	4	8	MEDIUM	Protect	Some email communications use standard unencrypted email. No policy requiring encrypted transmission of PHI.	REDUCE — Implement encrypted email solution for PHI transmission. Update data transmission policy to require encryption. Train staff on proper PHI communication.	IT Manager / Privacy Officer	July 2026	Open	1	3
WPH-R10	Staff have not completed annual HIPAA security awareness training — compliance gap	Compliance / Training	All Staff	3	3	9	MEDIUM	Protect	Training is required annually but completion is not tracked systematically. No consequences for non-completion.	REDUCE — Implement LMS-based training tracking. Set 100% completion target with management escalation for non-compliance. Report completion rates monthly.	HR Manager / GRC Analyst	June 2026	Open — In Progress	2	2
WPH-R11	No formal incident response plan exists — staff do not know what to do during a cyber incident	Incident Response	Entire Organization	2	5	10	MEDIUM	Respond / Recover	No documented incident response plan. IT handles incidents informally with no defined escalation path.	REDUCE — Develop formal Incident Response Plan aligned to NIST CSF. Define roles and responsibilities. Conduct tabletop exercise within 90 days of plan completion.	GRC Analyst / CISO	June 2026	Open — High Priority	1	3
WPH-R12	Unauthorized visitor gains physical access to server room due to lack of access controls	Physical Security	Server Room / Infrastructure	2	4	8	MEDIUM	Protect	Server room has a basic door lock. No key card system. Visitors can access the area with staff.	REDUCE — Install key card access system on server room. Implement visitor log. Install security camera covering server room entrance.	Facilities Manager / IT Manager	August 2026	Open	1	3
WPH-R13	Weak or default passwords on administrative and privileged IT accounts across hospital systems	Access Control	IT Systems / Network	3	4	12	HIGH	Protect	Password policy exists on paper but complexity requirements are not technically enforced on all systems.	REDUCE — Enforce password complexity technically on all systems. Implement Privileged Access Management (PAM) for admin accounts. Require MFA for all privileged access.	IT Manager	June 2026	Open — In Progress	1	3
WPH-R14	No monitoring of who accesses patient records — HIPAA audit log requirement not being met	Compliance / Audit	EHR / Patient Data	3	3	9	MEDIUM	Detect	Epic EHR has audit logging capability enabled but no process for regular review or alerting.	REDUCE — Establish monthly audit log review process. Implement automated alerting for unusual access patterns. Assign Privacy Officer responsibility for reviews.	Privacy Officer	June 2026	Open	2	2
WPH-R15	Cloud storage vendor holding backup patient data has no SOC 2 certification or security documentation	Vendor Risk	Cloud Storage / Patient Data	2	3	6	MEDIUM	Identify / Protect	Vendor selected based on cost only. No security assessment conducted prior to engagement.	REDUCE — Request SOC 2 Type 2 report from vendor. If unavailable, conduct security questionnaire assessment. Include security requirements in contract renewal.	GRC Analyst	July 2026	Open	1	2

WHITE PLAINS HOSPITAL | CYBERSECURITY RISK HEAT MAP | April 2026

Risk positioning based on Likelihood (1–5) × Impact (1–5). Each cell shows Risk IDs falling in that zone.

rowsLIKELIHOOD → (cols)

	IMPACT	1 Very Low	2 Low	3 Moderate	4 High	5 Very High
5 — Catastrophic (Severe: regulatory action, mass breach)		Score: 5	Score: 10	Score: 15	Score: 20	Score: 25
4 — Critical (Major: notifiable breach, disruption)		Score: 4	Score: 8	Score: 12	Score: 16 WPH-R02 WPH-R04	Score: 20 WPH-R01
3 — Major (Significant but containable)		Score: 3	Score: 6	Score: 9 WPH-R10 WPH-R14	Score: 12 WPH-R05 WPH-R08 WPH-R13	Score: 15 WPH-R03
2 — Minor (Limited impact, quickly resolved)		Score: 2	Score: 4	Score: 6 WPH-R15	Score: 8 WPH-R09 WPH-R12	Score: 10 WPH-R06 WPH-R07 WPH-R11
1 — Negligible (Minimal: no patient harm)		Score: 1	Score: 2	Score: 3	Score: 4	Score: 5

RISK LEVEL LEGEND	
CRITICAL (Score 20–25)	Immediate action required. Escalate to CISO and executive leadership. Treat within 30 days.
HIGH (Score 12–19)	Urgent attention required. Assign owner and treatment plan. Address within 60 days.
MEDIUM (Score 6–11)	Monitor closely. Develop treatment plan. Address within 90 days.
LOW (Score 1–5)	Accept or monitor. Review at next quarterly assessment.

AXIS NOTE: Rows = Impact (1=Negligible to 5=Catastrophic) | Columns = Likelihood (1=Very Low to 5=Very High)